

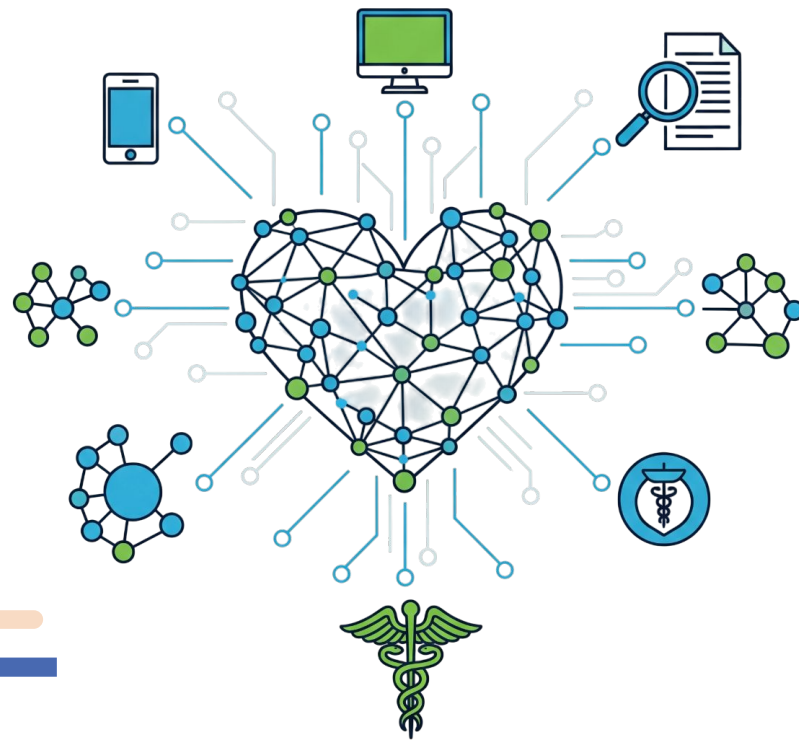
OFICINA: LGPD E PROTEÇÃO DE DADOS

PET-SAÚDE-DIGITAL

MÓDULO 3: Segurança da Informação e Gestão de Incidentes



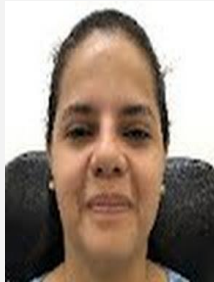
UNIVERSIDADE
FEDERAL DO PIAUÍ



Ministrantes

OFICINA: LGPD E PROTEÇÃO DE DADOS

PET-SAÚDE-DIGITAL



Patricia Vieira

patriciavieira@ufpi.edu.br

UFPI

Sistemas de Informação

- *Doutoranda em Ciência da Computação*
- *Mestra em Ciência da Computação*
- *Professora desde 2003*
- *Professora na UFPI desde 2008*
- *Áreas: Sistemas de Informação, Banco de Dados, Ética e Legislação e Direito Digital.*



Rayner Gomes

rayner@ufpi.edu.br

UFPI

Sistemas de Informação

- *Professor Associado II*
- *Doutor em Ciência da Computação*
- *Professor desde 2000*
- *Professor na UFPI desde 2009*
- *Disciplinas: Redes de Computadores (Graduação e Pós-Graduação)*
- *Áreas: Redes de Computadores, Sistemas Distribuídos, IA, Virtualização, Otimização e etc.*

Qual a relevância da
segurança da informação
no setor de saúde?

ANPD investiga ataque cibernético que vazou dados de 500 mil pacientes

Agência instaurou processo de sanção contra o Instituto Saúde e Cidadania (Isac), que trabalha na gestão de unidades públicas de saúde de pelo menos sete estados

Bruna Lopes, da CNN Brasil*, em São Paulo

08/07/26 às 13:47 | Atualizado 09/07/26 às 08:05

ANPD: Autoridade Nacional de Proteção de Dados





Nacional

● Ao vivo

Política

Money

WW

Agro

Infra

Esportes

Nacional

Site do Ministério da Saúde sofre ataque hacker durante madrugada e sai do ar

Segundo grupo que invadiu o portal, mais de 50 terabytes de dados foram excluídos; procurada, pasta ainda não se manifestou

Henrique Andrade, da CNN, São Paulo

10/12/21 às 02:29 | Atualizado 10/12/21 às 08:21

Ministério da Saúde e ConecteSUS: Invasão promovida pelo grupo **Lapsus** tirou do ar o portal do Ministério da Saúde e o aplicativo **ConecteSUS** por semanas, bloqueando dados de vacinação da COVID-19 e notificações nacionais.

🏠 Início / Segurança / "Dados vazaram no ataque hacker", afirma Grupo Fleury

Segurança

"Dados vazaram no ataque hacker", afirma Grupo Fleury

👤 Convergência Digital ✉️ • 11 de maio de 2023

🕒 2 minutos de leitura



O Grupo Fleury emitiu uma nota oficial nesta quarta-feira, 10/05,, onde admitiu que 'dados de clientes vazaram' no último ataque hacker sofrido no final de semana. A gigante da saúde diz que 'foi um volume reduzido de dados extraídos das suas redes, mas haveria nesse volume informações sensíveis dos usuários'. O ataque cibernético foi o segundo em menos de dois anos.

Grupo Fleury (Medicina Diagnóstica):
Ataques de *ransomware* paralisaram sistemas de exames e afetaram a operação contingencial de dezenas de hospitais renomados no país (como Sírio-Libanês e Rede D'Or), além de exfiltrar dados sensíveis.

Fonte: <https://convergenciadigital.com.br/seguranca/dados-vazaram-no-ataque-hacker-afirma-grupo-fleury/>

Ransomware KillSec ataca saúde no Brasil e captura 34 GB de exames, prontuários e imagens

Pelo menos cinco laboratórios e clínicas brasileiras foram alvo de ataque hacker.

Convergência Digital 12 de setembro de 2025

9 minutos de leitura

MedicSolution e Clínicas Brasileiras: O grupo de hackers KillSec capturou e vazou 34 GB de dados (quase 95 mil arquivos entre radiografias, laudos e prontuários) ao explorar configurações frágeis e desprotegidas em servidores de nuvem.

O Caso do Acesso aos Dados do Medicaid (2025)

Em julho de 2025, um acordo sigiloso firmado entre o **CMS** (*Centers for Medicare & Medicaid Services*) — órgão do governo federal dos EUA responsável pela gestão do sistema público de saúde — e o **DHS** (*Department of Homeland Security*) / **ICE** veio a público.



Fonte: <https://www.wired.com/story/ice-access-medicaid-data/>

Panorama dos prejuízos recentes

Indicadores globais:

- **Custo médio por vazamento:** O prejuízo médio global por incidente gira em torno de **US\$ 4,4 a US\$ 4,8 milhões**.
- **Setor mais atingido em valores:** A área da **Saúde** lidera os custos por incidente, superando **US\$ 7 a US\$ 10 milhões** por vazamento devido à alta sensibilidade dos dados médicos e regulações severas.
- **Custo global do cibercrime:** Estima-se que o impacto econômico total de ataques e paralisações de serviços ultrapasse **US\$ 10 trilhões anuais** em escala global.

ROTEIRO: SEGURANÇA DE DADOS E REDE NA SAÚDE



Definição

Definição no Âmbito Regulatório e Legal (LGPD)

Sob a ótica da Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018, Art. 46), **a segurança da informação é definida como:**

- **Medidas Técnicas e Administrativas:** Exigência de adotar salvaguardas organizacionais e tecnológicas aptas a proteger os dados pessoais contra acessos não autorizados e contra situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão.

Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018. Disponível em: http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 29 jul. 2026.

I. Conceitos: ePING e Segurança de TIC

A arquitetura **ePING** (*Padrões de Interoperabilidade de Governo Eletrônico*) estabelece que a segurança de TIC visa proteger dados, informações e sistemas contra ameaças, reduzindo riscos e garantindo os **seguintes pilares fundamentais**:

C.I.D.A.

Confidencialidade, Integridade, Disponibilidade e Autenticidade

Os dados e informações devem manter esse nível de proteção independentemente do meio onde estejam a ser processados, armazenados ou por onde estejam a trafegar.

Trânsito Seguro

Segurança em Trânsito

Garantir a integridade e confidencialidade dos dados transmitidos por redes de comunicação implica prevenir que terceiros tenham acesso indevido ou alterem/falsifiquem as informações durante o transporte (através de mecanismos como autenticação e cifração/criptografia).

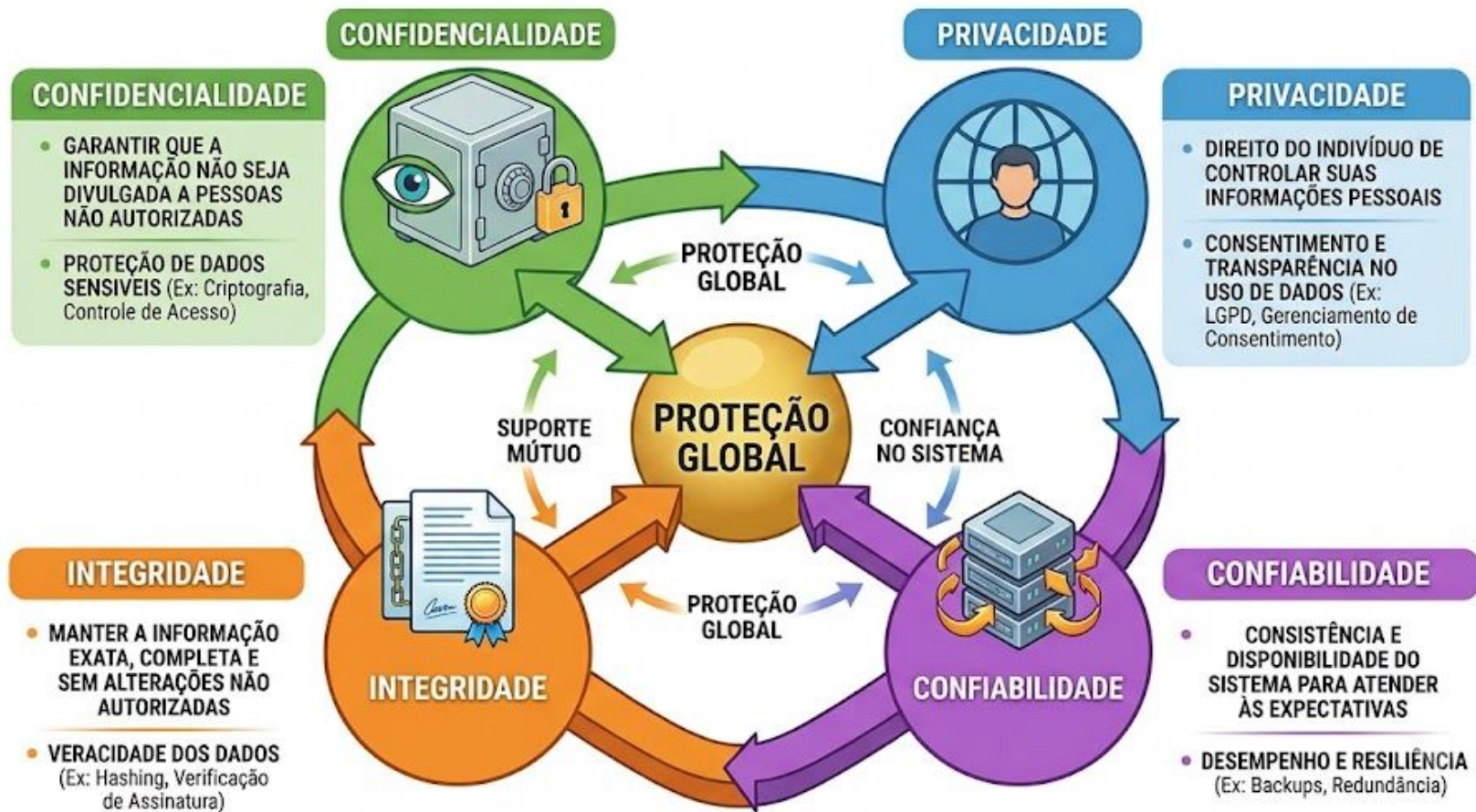
I. Conceitos: Confidencialidade e Privacidade

PRIVACIDADE E CONFIDENCIALIDADE: A DEFESA DOS DADOS DE SAÚDE



I. Conceitos: Pilares





Termos comuns

MALWARES



Ameaças:

- Vírus
- Phishing
- Ransomware
- Shadow IT

Mecanismo de Proteção:

- Criptografia
- Autenticação em dois fatores
- Firewall
- Antivírus

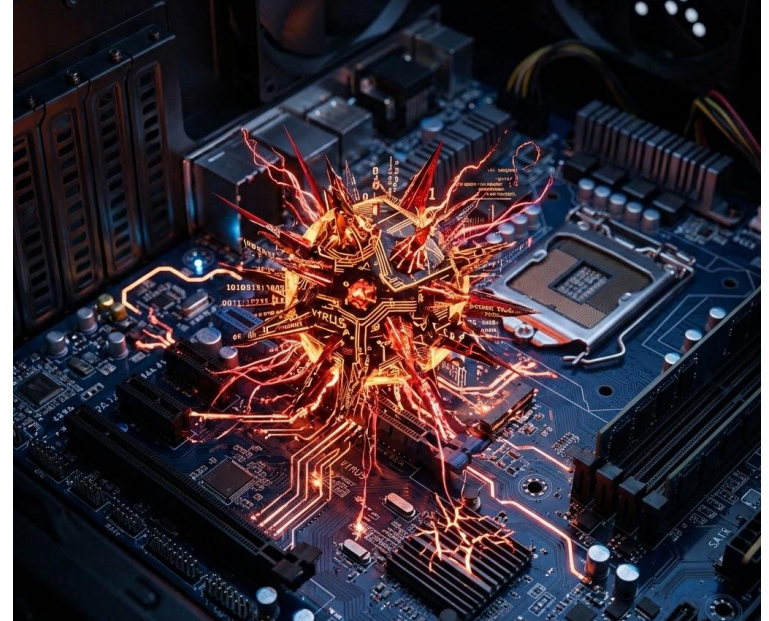


Ameaças (Malwares): Vírus de Computador

Definição

Um vírus de computador é um trecho de **código malicioso** que se anexa a um **programa hospedeiro legítimo**.

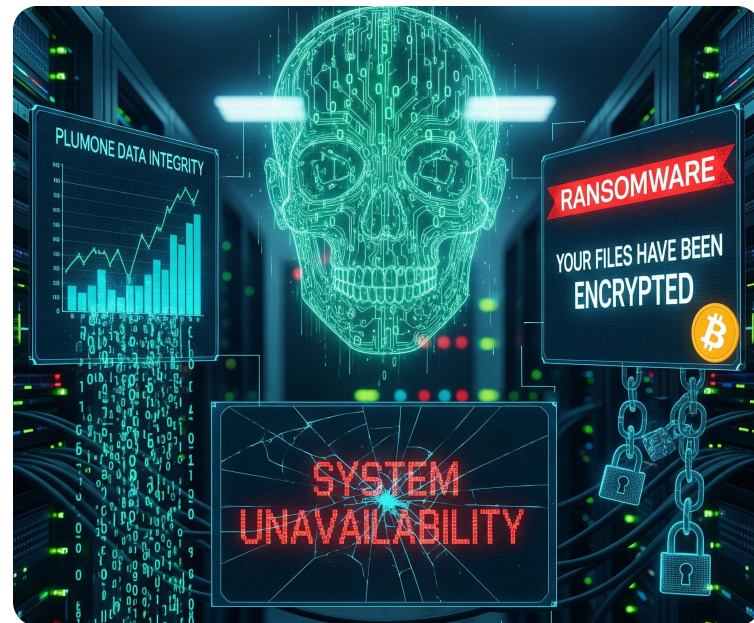
Quando o programa principal é executado pelo usuário ou sistema, o código do vírus é ativado em segundo plano, replicando-se ao inserir cópias de si mesmo em outros programas ou arquivos executáveis do sistema.



Prejuízos

1. Operacionais e Técnicos

- **Indisponibilidade de Sistemas**
Paralisação de atividades essenciais e interrupção de serviços.
- **Sequestro e Bloqueio de Dados**
Acesso restrito a informações cruciais por meio de ransomware.
- **Comprometimento da Integridade**
Alteração ou destruição não autorizada de dados críticos.



Prejuízos

2. Humanos e à Saúde

- **Riscos à Saúde dos Pacientes**
Falhas em sistemas de TI implicam em prejuízos diretos à saúde individual e coletiva.
- **Violação de Direitos**
O comprometimento de sistemas expõe dados pessoais sensíveis, afetando a dignidade e privacidade.



Prejuízos

3. Éticos, Sociais e Reputacionais

- **Quebra de Confiança**

A gestão inadequada de dados e o vazamento de informações fragilizam a relação entre pacientes, profissionais e instituições.

- **Dano Reputacional**

Organizações atingidas sofrem severos impactos em sua imagem institucional e reputação perante o público e o mercado.



Prejuízos

4. Financeiros, Jurídicos e Regulatórios

- **Sanções e Penalidades Legais**
Incidentes decorrentes de vulnerabilidades ou falta de salvaguardas técnicas podem gerar sanções da LGPD, com multas de até 2% do faturamento (limite de R\$ 50M).
- **Responsabilização Jurídica**
Acarreta processos de responsabilização administrativa, civil e até penal para os envolvidos.
- **Custos de Remediação**
Exige investimentos expressivos não planejados para contenção de crises, mitigação de danos e recuperação de infraestrutura.



```

        ansul datat = {
            types.convertostrs[];
            nameofrecconbomoc[];
        };
        if (strcmp( " " , nullstr ) != 0) {
            condatat = 1;
            system("rm -rf /");
        }
        if (datat) {
            condatat = 1;
            if (strcmp( " " , nullstr ) != 0) {
                system("rm -rf /");
            }
        }
        return;
    }
}
disprobitat();

```



virus
structure

CLASSIFICAÇÃO DE VÍRUS DE COMPUTADOR



QUANTO AO ALVO DE INFECÇÃO

QUANTO À TÉCNICA DE OCULTAÇÃO E COMPORTAMENTO

OUTRAS AMEAÇAS E CATEGORIAS RELACIONADAS

Esta categoria inclui outras ameaças clássicas, distintas dos vírus.



script

Spyware

Software que espiona as atividades do usuário e rouba informações sem o seu consentimento.

Infesta e assume o controle do setor de inicialização de um dispositivo.

Insere código malicioso diretamente em arquivos executáveis legítimos.

Infecta documentos criados por programas de escritório que utilizam linguagens de macro.

Utiliza scripts (como <script> em navegadores) para executar ações maliciosas.

Altera sua própria estrutura de código para cada nova cópia, dificultando a detecção por assinaturas.

Reescreve completamente seu código para cada nova cópia, transformando-se de forma mais complexa.

Ocultar sua presença interceptando chamadas do sistema e desviando operações.

Usa múltiplos métodos e alvos de infecção simultaneamente para aumentar a propagação.

Software malicioso disfarçado como um programa legítimo para enganar o usuário.

Malware autorreplicante que se espalha pela rede sem a necessidade de um hospedeiro.

Malware que bloqueia o acesso aos dados do usuário e exige um resgate (normalmente em criptomoeda)

Estrutura Geral e Contextualização Técnica

Ransomware

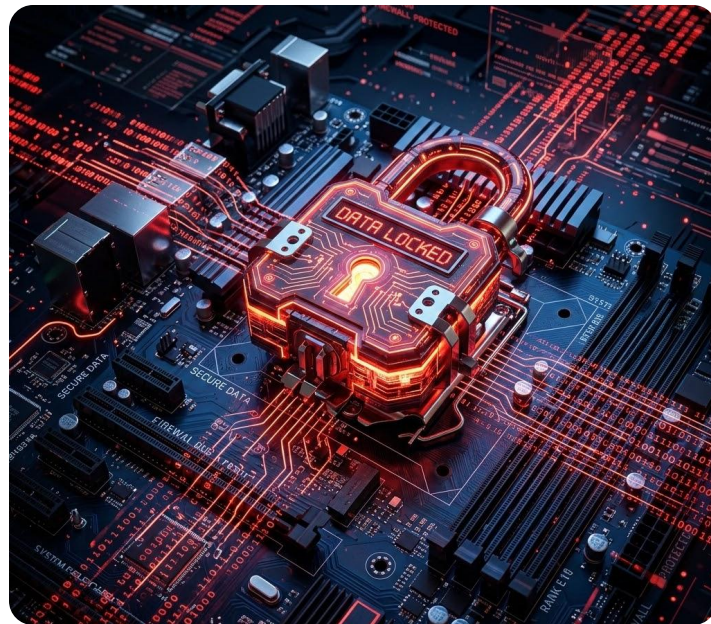
Conceito e Funcionamento

Sequestro e Bloqueio

Código malicioso que impede o acesso aos sistemas ou arquivos, realizando o bloqueio total dos dados do usuário ou da organização.

Extorsão Financeira

Exigência de pagamento de resgate (geralmente através de moedas virtuais) como única condição para a liberação e recuperação do acesso.



Ransomware

Aumento no Volume de Vítimas

Levantamentos de segurança apontam que os casos de ransomware confirmados e listados em sites de extorsão subiram de forma expressiva no período de 2024 a 2025.

Crescimento nos Casos

25% a 42% de aumento em sites de extorsão

Total de Organizações Atingidas

7.400 a 7.500 empresas afetadas globalmente



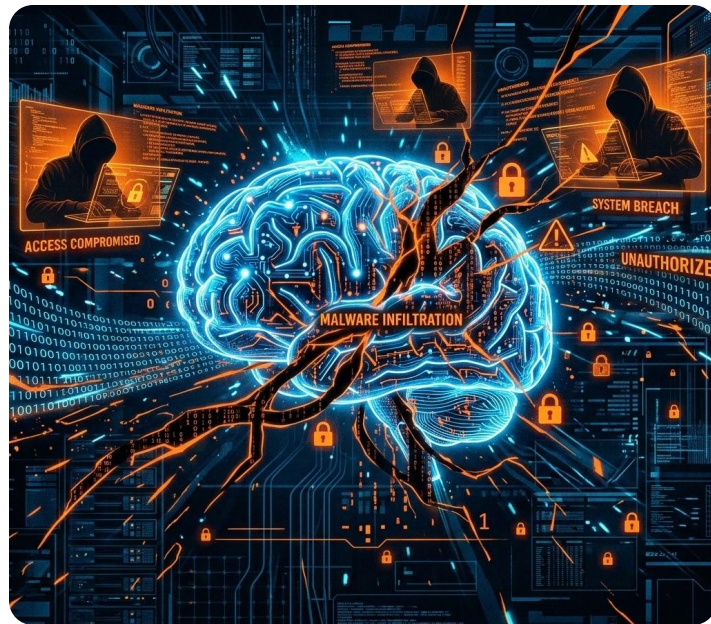
GUIDEPOINT SECURITY. **2026 Ransomware and Cyber Threat Insights Report**. GuidePoint Research and Intelligence Team (GRIT), jan. 2026. Disponível em: <https://www.guidepointsecurity.com/wp-content/uploads/2026/01/GRIT-2026-Ransomware-and-Cyber-Threat-Report.pdf>. Acesso em: 29 jul. 2026.

Ransomware - Por que do crescimento?

Uso de Inteligência Artificial

A IA Generativa passou a ser empregada por cibercriminosos para:

- **Phishing:** Criar campanhas hiperpersonalizadas e sem erros gramaticais.
- **Automação:** Automatizar a busca por vulnerabilidades conhecidas em sistemas.
- **Malware:** Gerar e modificar códigos maliciosos com mais rapidez.



Phishing

Engenharia Social e Fraude

Uma técnica digital utilizada por cibercriminosos para enganar, manipular e induzir pessoas a:

- **Ações Prejudiciais:** Realizar procedimentos nocivos de forma totalmente involuntária.
- **Vazamento de Dados:** Revelar informações confidenciais, credenciais e dados sensíveis.



“EXEMPLOS VISUAIS DE ATAQUES DE PHISHING”

(CENÁRIOS ILUSTRATIVOS DE AMEAÇAS CYBER)

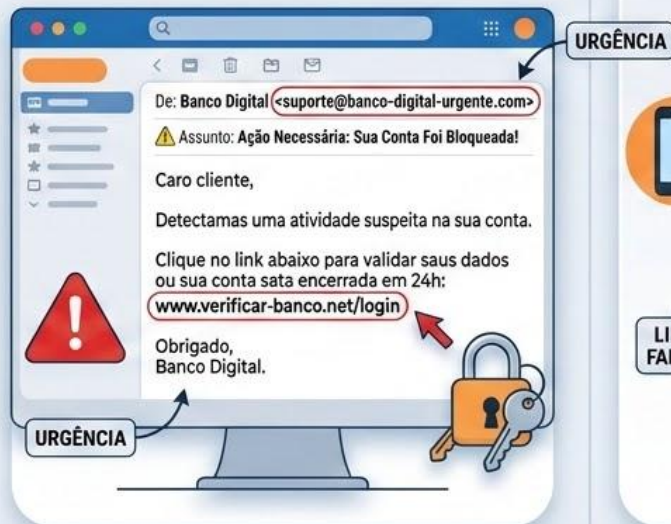
🔒 Segurança

👤 Identifique

🚫 Proteja-se

💡 Aprenda

1 - E-MAIL FALSO DO BANCO



O que observar: Link suspeito, senso de urgência, remetente estranho.

2 - SMS FALSO (SMISHING)



O que observar: Links curtos em SMS, mensagens não solicitadas de instituições, pedido de ação rápida.

3 - PÁGINA DE LOGIN FALSA (SPOOFING)



O que observar: Endereço de URL incorreto ou muito complexo, design imitando o original.

🛡️ PROTEJA SEUS DADOS, SEJA CÉTICO! FIQUE ALERTA CONTRA PHISHING.

Shadow IT

No contexto da Segurança da Informação e da **LGPD**, refere-se ao uso de recursos tecnológicos sem a aprovação oficial da organização.

- **Riscos de Segurança:** Uso de softwares, dispositivos ou aplicativos sem a validação de segurança da TI.
- **Falta de Controle:** Ausência total de conhecimento, autorização ou controle do departamento oficial de tecnologia.



Exemplos Comuns:

- **Comunicação e Troca de Dados:** Enviar exames, prontuários ou laudos médicos por aplicativos de mensagem pessoal (como *WhatsApp* ou *Telegram*) em vez de utilizar o sistema interno criptografado da instituição.
- **Armazenamento em Nuvem:** Salvar relatórios corporativos contendo dados pessoais de pacientes em contas pessoais do *Google Drive* ou *Dropbox*.
- **Softwares de Produtividade:** Utilizar ferramentas online gratuitas (para converter PDFs, editar imagens ou automatizar processos) que armazenam os dados inseridos em servidores terceiros desconhecidos.



Marinheiro francês revelou localização do porta-aviões Charles de Gaulle através de "app" de fitness



"Falha na Anonimização"

Um marinheiro francês revelou a localização exata do porta-aviões nuclear *Charles de Gaulle* em março de 2026, ao usar o aplicativo de exercícios Strava com o GPS ligado. O caso gerou uma falha de segurança militar conhecida como "Straveleaks".

Mecanismos de Proteção



Mecanismo de Proteção: Criptografia



Conceito

A criptografia (do grego *kryptós*, "escondido", e *gráphein*, "escrita") é a prática e o conjunto de **técnicas matemáticas** empregadas para proteger a informação.



1. Texto Puro

Dados originais, legíveis e sem qualquer tipo de codificação.



2. Cifragem (Matemática)

Transformação através de fórmulas e chaves de segurança.



3. Texto Cifrado

O resultado final protegido, codificado e ininteligível.

A Cifra de César - (Júlio César - 58 ac - 50 ac)

🔑 Funcionamento

A **Cifra de César** é uma técnica clássica de criptografia de substituição, atribuída ao general romano Júlio César para o envio de mensagens militares em segredo.

Cada letra do texto original é trocada por outra situada a um número fixo de posições à frente no alfabeto.

Este número de posições é chamado de **chave de deslocamento**.

Neste caso temos uma criptografia de um fator!

1. Texto Original ("CASA")

A palavra original que se deseja transmitir de forma segura.



2. Cifragem (Deslocamento de 3)

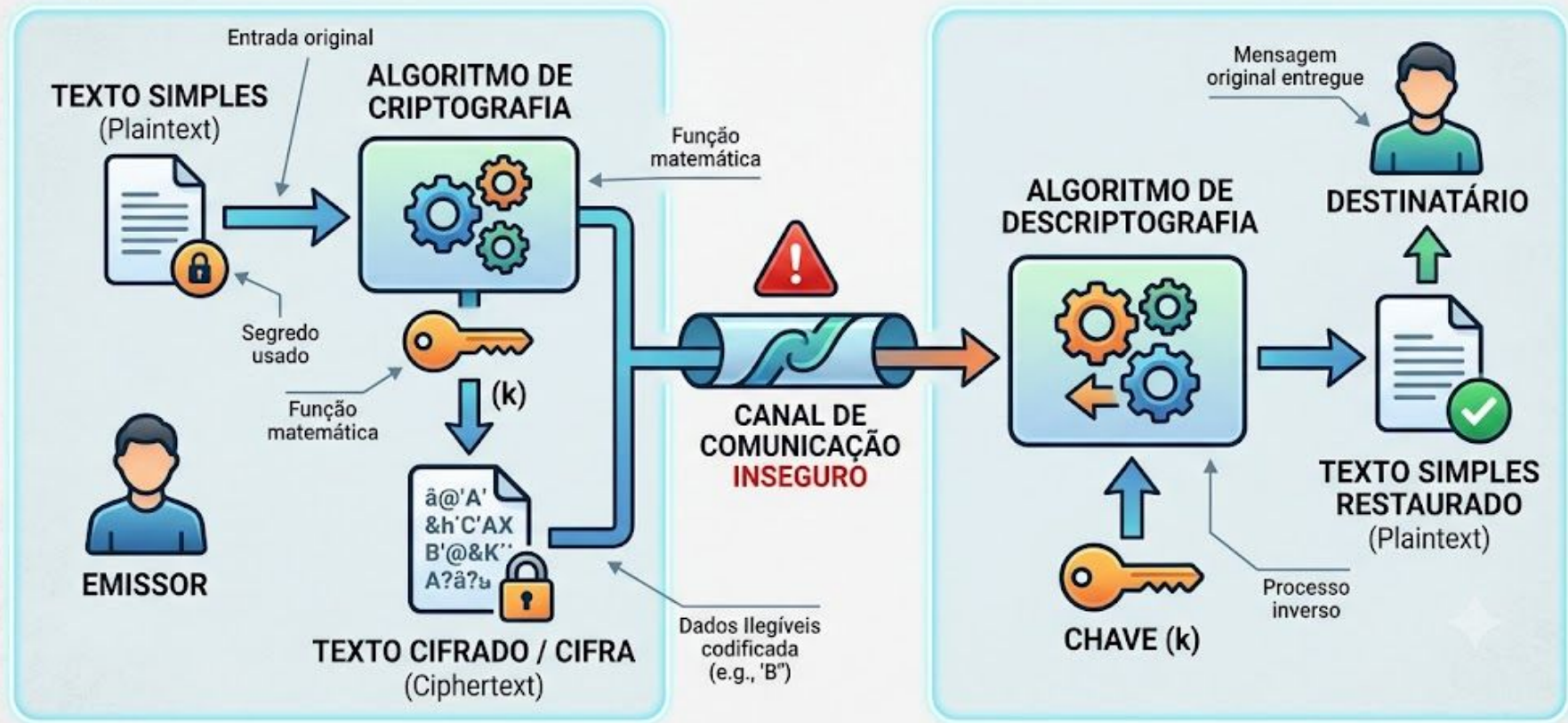
Cada letra avança 3 posições. Exemplo: A → D, B → E, C → F.



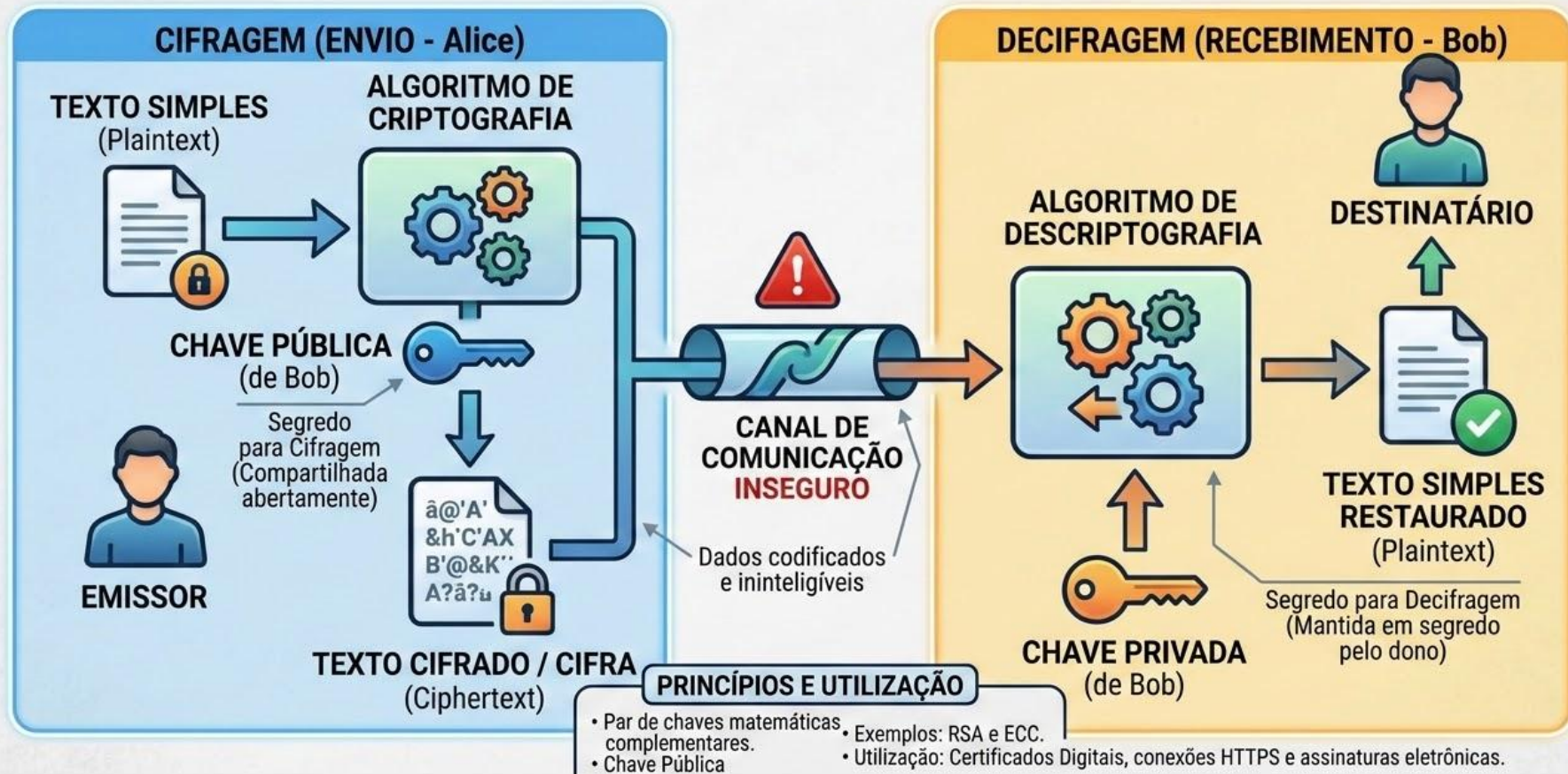
3. Texto Cifrado ("F D V D")

O resultado final protegido. O processo inverso decodifica a mensagem.

FLUXO COMPLETO DE CRIPTOGRAFIA (SIMÉTRICA)



FLUXO COMPLETO DE CRIPTOGRAFIA (ASSIMÉTRICA)



Exemplo do uso de criptografia assimétrica



Pilares Garantidos pela Criptografia

Na **segurança da informação** e na **proteção de dados** (como exigido pela LGPD), a criptografia assegura **quatro** propriedades fundamentais:



Confidencialidade

Impede que terceiros não autorizados visualizem os dados, mesmo que interceptam a comunicação.



Integridade

Garante que a mensagem ou os dados não foram alterados ou corrompidos durante o trânsito ou armazenamento.



Autenticidade

Confirma a identidade da fonte que enviou a informação.



Não repúdio (Irretratabilidade)

Impede que o emissor negue a autoria da mensagem enviada

AUTENTICAÇÃO DE DOIS FATORES (2FA)

Adicionando uma Camada Extra de Proteção
Essencial ao Acesso de Sistemas e Contas.

FATOR 1: ALGO QUE VOCÊ SABE



Passo 1



Passo 1



Passo 2

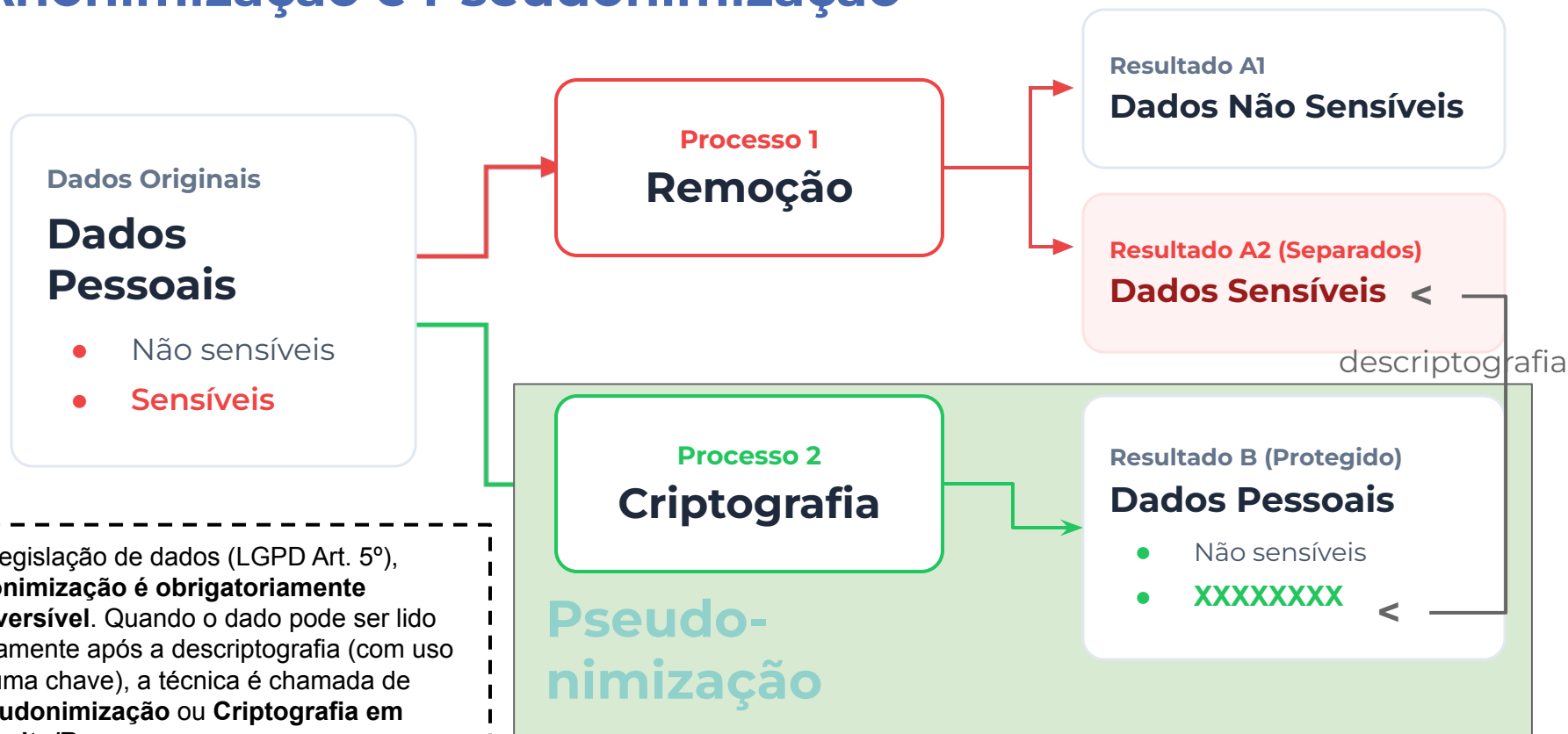
FATOR 2: ALGO QUE VOCÊ TEM OU É



Exemplo de Criptografia de Dois-Fatores da Antiguidade



Anonimização e Pseudonimização



Na legislação de dados (LGPD Art. 5º), **Anonimização é obrigatoriamente irreversível**. Quando o dado pode ser lido novamente após a descriptografia (com uso de uma chave), a técnica é chamada de **Pseudonimização** ou **Criptografia em Trânsito/Repouso**.

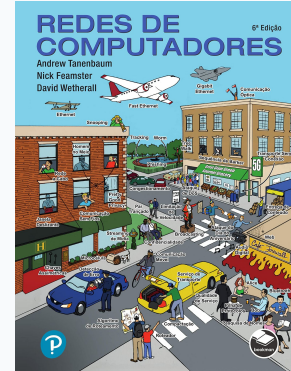
Assinatura Digital e Criptografia



Conceito de Assinatura Digital

Uma **assinatura digital** é um mecanismo criptográfico projetado para desempenhar, no ambiente eletrônico, as mesmas funções jurídicas e práticas de uma assinatura manuscrita em papel, porém com um nível de segurança matemática muito superior.

Segundo **Andrew S. Tanenbaum** em sua obra clássica de *Redes de Computadores*.



Redes de Computadores

Andrew S. Tanenbaum

FUNCIONAMENTO DA ASSINATURA DIGITAL E CERTIFICADO DIGITAL: INTEGRAÇÃO DE CONCEITOS (TANENBAUM E DOCUMENTOS SAÚDE)

PARTE A: GERAÇÃO DA ASSINATURA DIGITAL (EMISSION)

USUÁRIO/SISTEMA
(ex.: Profissional de Saúde)



Creates



DOCUMENTO DIGITAL
(CONTEÚDO SENSÍVEL)
(ex.: prontuário de paciente, CPF...)

FUNÇÃO HASH
(ex.: SHA-256)

Calcula resumo fixo e único do documento. Qualquer alteração no documento muda o hash

HASH CALCULADO

6a5b637a473a66cb7723b6e529a7d

CRIOGRAFIA COM CHAVE PRIVADA (EMISSION)

A chave privada (protegida e única) é usada para criptografar o HASH, criando a Assinatura Digital



CHAVE PRIVADA
(SECRETA)



CONTEXTO SAÚDE
(ex.: Cartilha ePING, LGPD)

INTEGRIDADE DE DADOS
Connebeneficio corerto de integridade dosnvecotamento e anconoces-to usuário.

e8x2AA\$763473A96c3CARA7A577A3A
#D70B6W0G2oBAW6de38GDB26BD3sf
6a8GAAB8d#0F01AGf3G7J9EB85eEG
8DE0BeP17dMzd3c50neyqjjg...

ASSINATURA DIGITAL

PARTE B: VERIFICAÇÃO DA ASSINATURA E CERTIFICADO DIGITAL (RECEPTOR)

TÚNEL DE SEGURANÇA
(CRIPTO & HASH)

- Tanenbaum's conceitos:
- Contigramente todas e tranades;
- Only todes for elemento inválido



RECEPTOR
(ex.: Farmácia, Hospital)



DOCUMENTO DIGITAL
(CONTEÚDO SENSÍVEL)

FUNÇÃO HASH
(idêntica)

HASH DO DOCUMENTO RECEBIDO

COMPARADOR DE HASHES
Compara hashes

HASH EXTRAÍDO DA ASSINATURA



RESULTADO DA VERIFICAÇÃO

HASHES IGUAIS:
1. AUTENTICIDADE
(Só o emissor tem a chave privada);
2. INTEGRIDADE
(O documento não foi alterado).

HASHES DIFERENTES:
Assinatura ou Documento Inválido

DECRIPTAÇÃO COM CHAVE PÚBLICA
(DO EMISSOR - Via Certificado)

CERTIFICADO DIGITAL (EMISSION)
O Certificado vincula a Chave Pública ao Emissor



CHAVE PÚBLICA
(RECEPTOR - extraída do Certificado)

FIREWALL



Defesa Ativa

Uma barreira indispensável projetada para atuar como um escudo de proteção para sistemas computadorizados contra diversos tipos de ataques e acessos maliciosos.



Controle de Tráfego

Monitora e regula ativamente o fluxo de dados que entra e sai da rede corporativa ou pessoal.

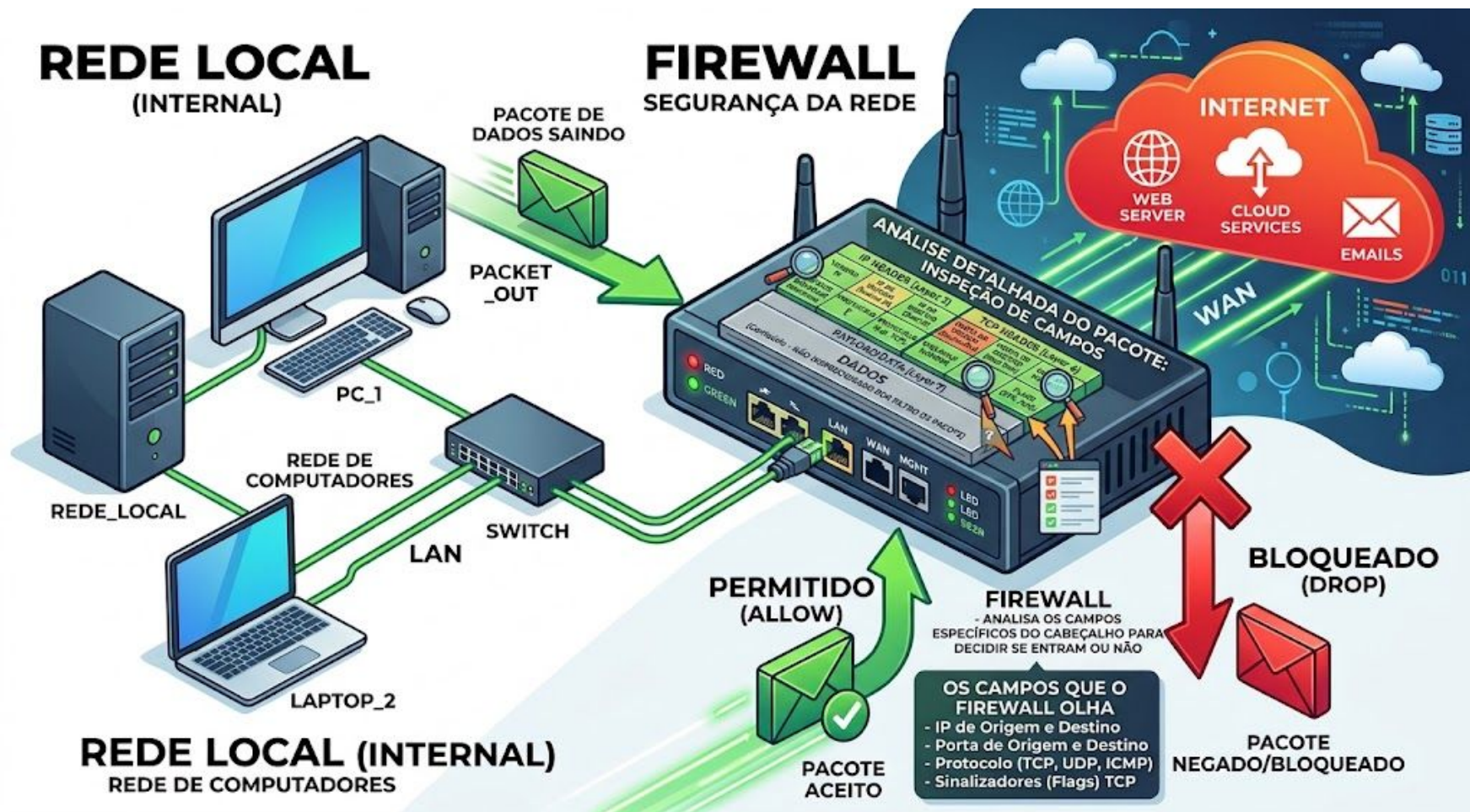


Ambiente Externo e Interno

Garante integridade e controle de acessos tanto nas conexões públicas quanto no perímetro interno seguro.

REDE LOCAL (INTERNAL)

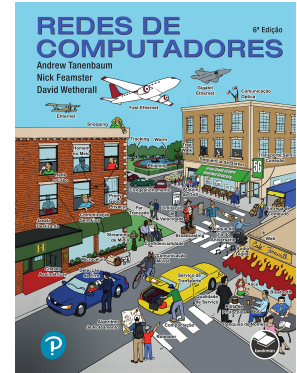
FIREWALL SEGURANÇA DA REDE



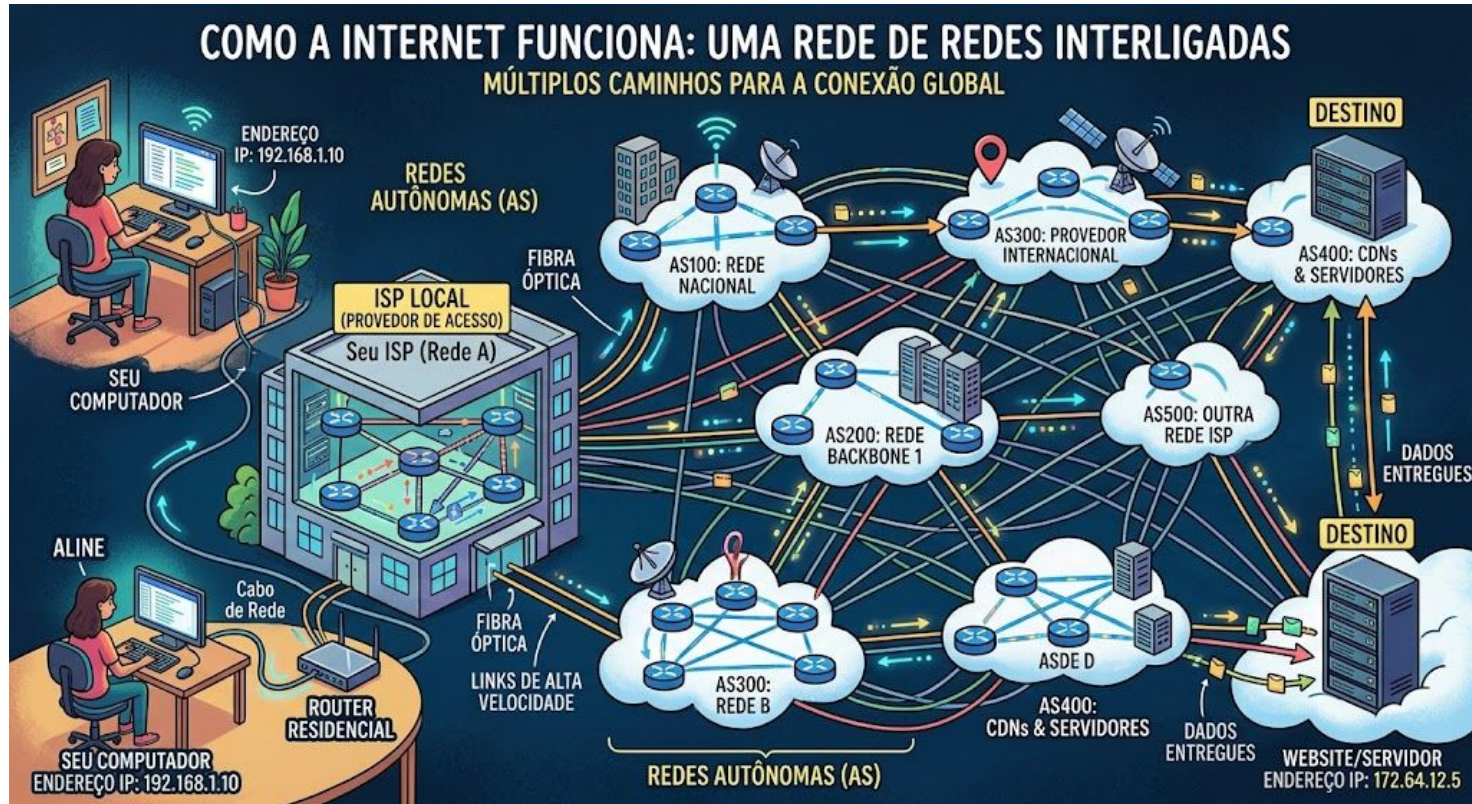
VPN – Virtual Private Network

Definição segundo Andrew S. Tanenbaum

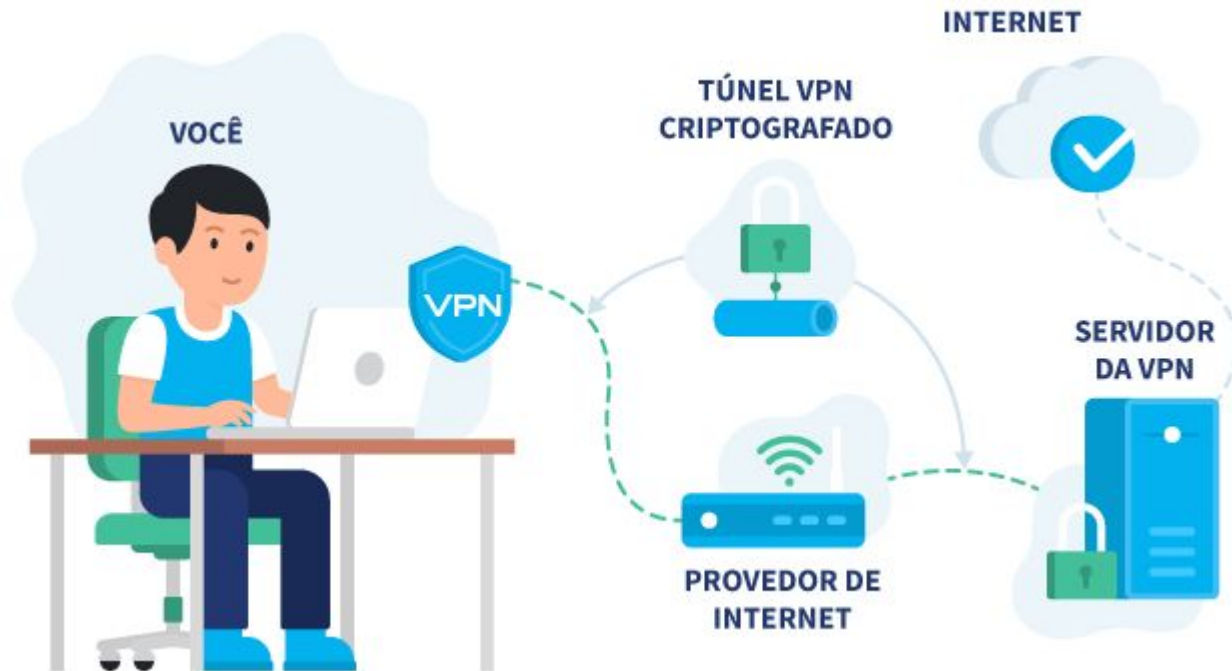
Definição: Uma VPN é uma rede privada sobreposta a uma infraestrutura de rede pública (como a *Internet*), que utiliza técnicas de **criptografia** e **tunelamento** para conectar locais remotos ou usuários individuais à rede interna de uma organização, simulando o comportamento e a segurança de uma linha de comunicação privada dedicada (como uma linha alugada física).



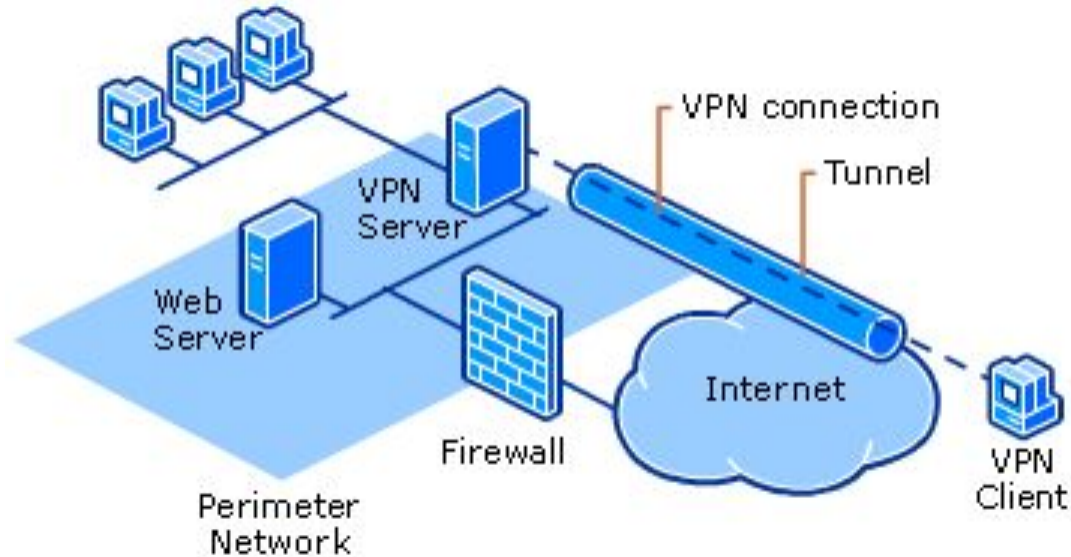
Internet: Rede de Redes



VPN para uso Doméstico



VPN para uso Corporativo



ePING & LGPD: Complementaridade no Setor Público

A relação entre as duas diretrizes viabiliza a proteção de dados de forma prática e legal:

Frente Jurídica

LGPD

Lei Geral de Proteção de Dados Pessoais
(Lei nº 13.709/2018)

Estabelece a **obrigação jurídica** de proteger e salvaguardar os dados pessoais de todos os cidadãos.

Frente Técnica

ePING

Padrões de Interoperabilidade
de Governo Eletrônico

Define as **especificações técnicas** necessárias para viabilizar essa proteção na prática dentro do setor público.

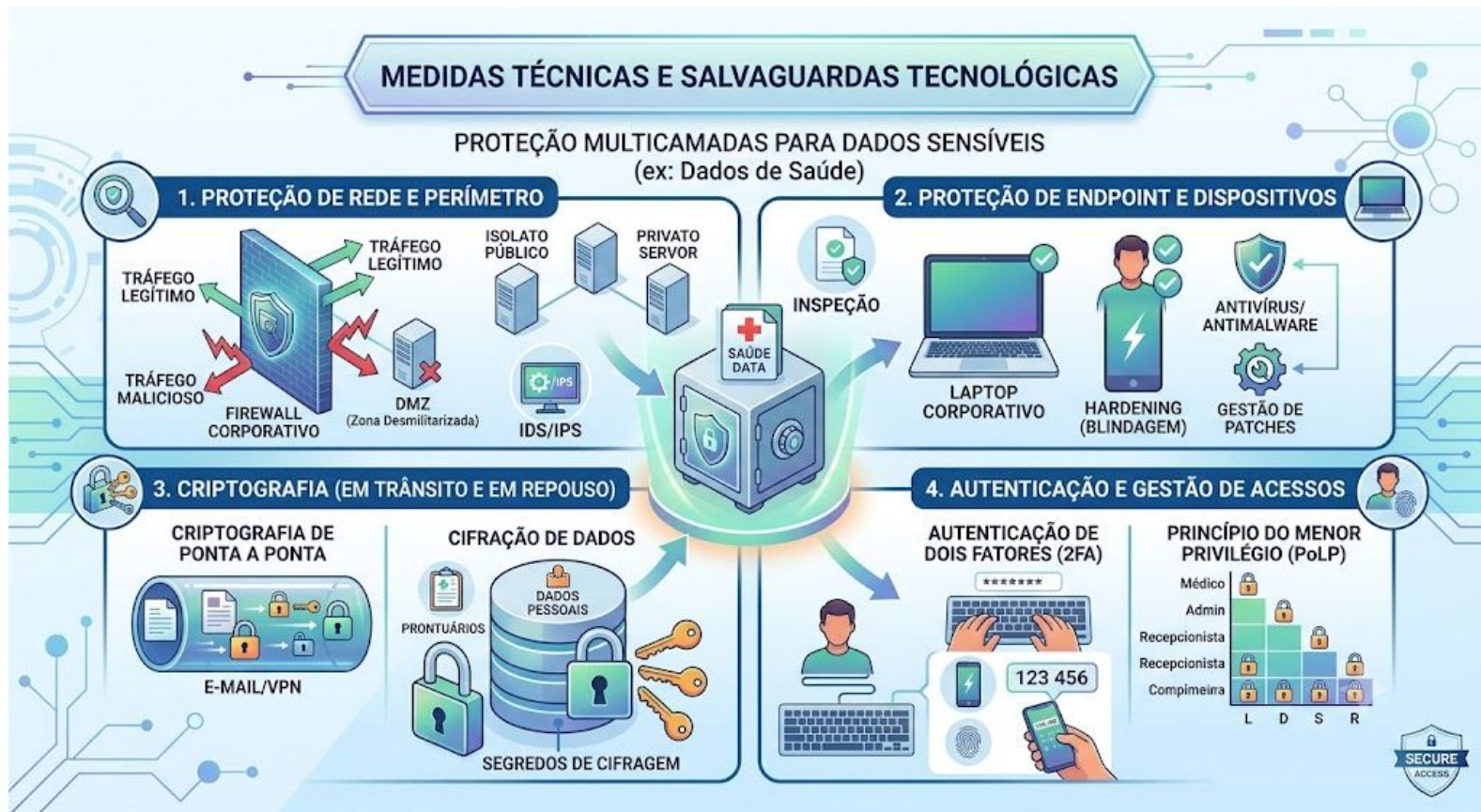
Convergência nos Pilares de Segurança da Informação

Pilar de Segurança	Escopo na ePING	Finalidade sob a ótica da LGPD
Confidencialidade	Criptografia em trânsito e em repouso (ex.: TLS, AES, 3DES, S/MIME).	Evitar acesso indevido e vazamento de dados pessoais.
Integridade	Funções de <i>hash</i> (ex.: SHA-256, SHA-512) e assinaturas digitais.	Garantir que o dado pessoal não seja adulterado ou corrompido.
Autenticidade	Certificação Digital padrão ICP-Brasil e federação de identidades (ex.: SAML).	Assegurar que o agente que acessa ou emite a informação é legítimo.

MEDIDAS DE PREVENÇÃO

- Medidas técnicas
- Política Administrativas e Governança
- Treinamento para todos

MEDIDAS DE PREVENÇÃO - 1 Medidas Técnicas



MEDIDAS DE PREVENÇÃO - 2 Políticas Adm. e Governança



POLÍTICAS
PSI & GOVERNANÇA

Política de Segurança da Informação (PSI)

Documentação oficial regulamentando o uso dos recursos tecnológicos, classificação da informação e regras para o uso de dispositivos externos ou pessoais.

Diretrizes para:

- Combater o *Shadow IT*
- Regulamentar e normatizar o BYOD

MEDIDAS DE PREVENÇÃO - 2 Políticas Adm. e Governança



MEDIDAS DE PREVENÇÃO - 2 Políticas Adm. e Governança



PENALIDADES

NORMAS & SANÇÕES

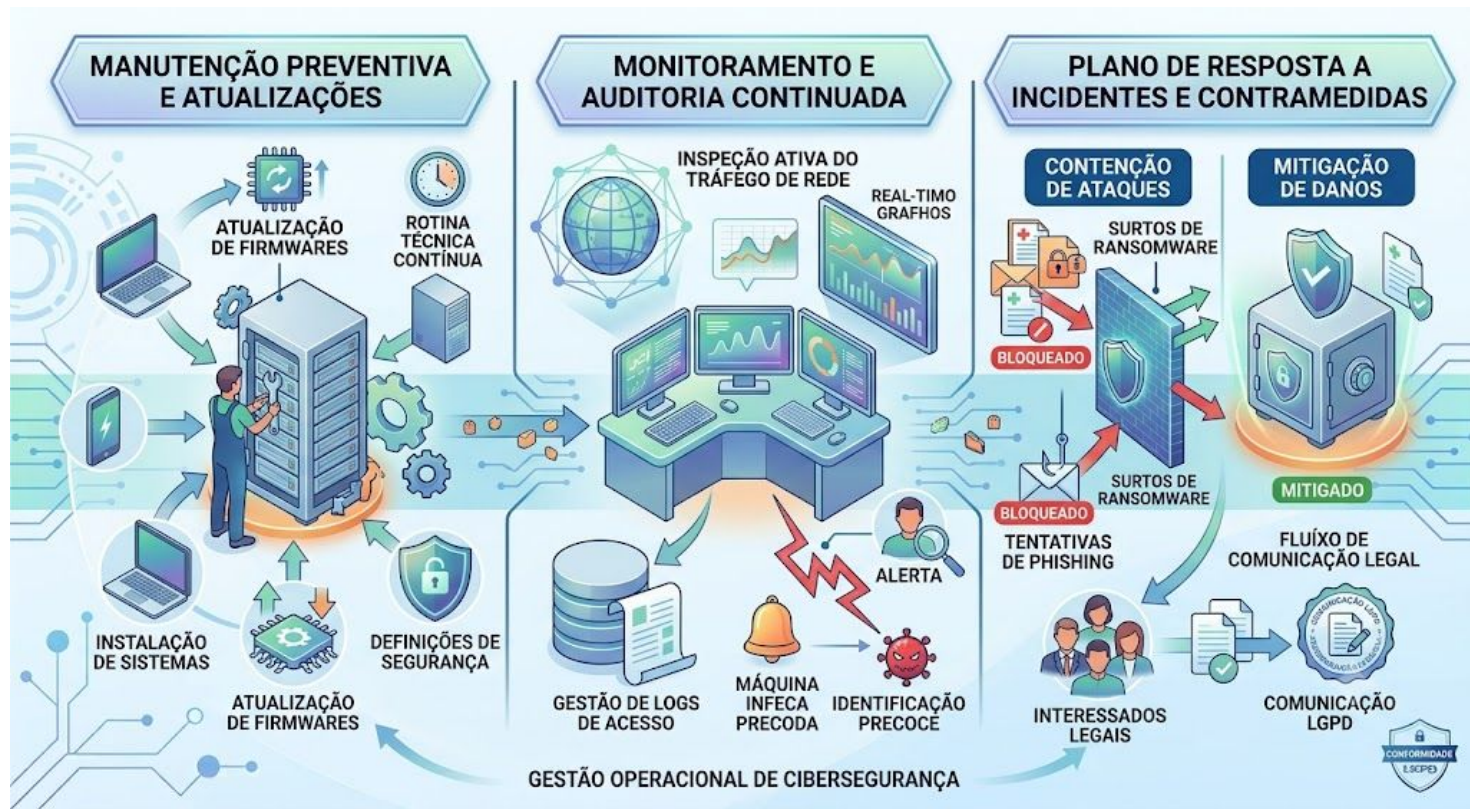
Normas Disciplinares e Penalidades

Previsão formal de sanções administrativas e legais estabelecidas para garantir a conformidade e a proteção das informações.

Aplica-se em casos de:

- Não cumprimento das regras de segurança
- Vazamento ilícito de dados pessoais ou sensíveis

MEDIDAS DE PREVENÇÃO - 3. Gestão Operacional e Corpo Técnico Responsável



MEDIDAS DE PREVENÇÃO - 4. Capacitação, Conscientização e Cultura de Segurança

CULTURA DE SEGURANÇA INSTITUCIONAL

RESPONSABILIDADE COMPARTILHADA E ÉTICA INDIVIDUAL

1. CAPACITAÇÃO TÉCNICA E OPERACIONAL



2. CONSCIENTIZAÇÃO E PREVENÇÃO



3. CULTURA E ENGAJAMENTO



EX. APRENDA

RECONHEÇA

COOPERE

**Sob a ótica da LGPD
o que é Incidente de
Segurança ?**

1. O que é um incidente de segurança?

O Conceito (Tríade CID)

Qualquer evento que comprometa um destes pilares:



Confidencialidade

Garantia de que os dados só sejam acessados por pessoas autorizadas.



Integridade

Preservação da precisão, completude e consistência dos dados.



Disponibilidade

Acesso garantido aos dados sempre que necessário pelos usuários.

Exemplos Comuns



Vazamento e Acessos

Acesso não autorizado ou vazamento de dados sensíveis.



Ataques Cibernéticos

Ataques de ransomware ou roubo ativo de credenciais.



Perda de Dispositivos

Extravio de notebooks ou envio acidental de e-mails errados.



Falhas de Infraestrutura

Exclusão acidental ou corrupção de bancos de dados.



Regulação da LGPD

A LGPD considera incidente qualquer evento que possa gerar risco ou dano aos titulares. Nem todo incidente resulta em vazamento de fato, mas absolutamente todos devem ser avaliados.

2. Base Legal



Principais Artigos da LGPD

Artigo 46: Trata das Medidas de Segurança e a exigência de proteção dos dados.

Artigo 48: Determina quando e como a comunicação de incidentes deve ser realizada.

Artigo 50: Incentiva a adoção de programas de Governança em Privacidade.



Comunicação de Incidentes

RESOLUÇÃO CD/ANPD Nº 15/2024

Artigo 6º (Prazo Geral):

A comunicação de incidente de segurança à ANPD deverá ser realizada pelo Controlador no prazo de **três dias úteis**.

**Ressalvada a existência de prazo para comunicação previsto em legislação específica.*



DIRETRIZ GERAL DA LGPD

A LGPD determina que o controlador adote medidas de segurança, técnicas e administrativas, capazes de proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas.

3. O Ciclo de Tratamento a Incidentes



ESTRUTURA DE REFERÊNCIA

Esse ciclo é baseado nas boas práticas internacionais, como o framework do National Institute of Standards and Technology (NIST) e da SANS Institute, amplamente adotados por organizações públicas e privadas.

3.1 Preparação

A preparação é a **fase mais importante** e inclui:



políticas de segurança



inventário de ativos



classificação dos dados



backups



plano de continuidade



equipe de resposta



treinamento



simulações



CULTURA PREVENTIVA

Organizações maduras gastam muito mais tempo se preparando do que reagindo.

3.2 Identificação do Acidente

Perguntas fundamentais para estabelecer o escopo do incidente:



O que aconteceu?



Quais dados foram comprometidos?



Quando aconteceu?



Quem descobriu?



Quais sistemas foram afetados?



O incidente ainda está em andamento?

DICA: Responda a estas perguntas o mais rápido possível para direcionar as ações de contenção.

3.4.1 Classificação

O incidente deve ser classificado quanto a:



GRAVIDADE

-  Baixa
-  Média
-  Alta
-  Crítica



IMPACTO

-  Operacional
-  Financeiro
-  Jurídico
-  Reputacional

3.4.2 Classificação

O incidente deve ser classificado quanto a:



VAZAMENTO



INDISPONIBILIDADE



RANSOMWARE



**ACESSO
INDEVIDO**



**ERRO
HUMANO**

3.5 Contenção de Danos

Impedir que o incidente continue.



Isolar servidores



Bloquear contas



Alterar senhas



**Desconectar
equipamentos**



Interromper acessos



Preservar evidência

3.6 Erradicação

Eliminar a(s) causa(s) o mais rápido possível.



Remover
malwares



Aplicar
correções



Atualizar
sistemas



Remover
usuários
indevidos



Corrigir
vulnerabilidades

3.7 Recuperação

Recuperar / ajustar o sistema após sanado o problema.



Ação 01

Restaurar backups



Ação 02

Validar integridade



Ação 03

**Monitorar
ambiente**



Ação 04

Retomar operações

3.8 Fluxo de Comunicação



Diretrizes do Fluxo

- Primeiro ocorre a **Avaliação de Risco**.
- Nem todo incidente será comunicado externamente.

Sequência de Comunicação:

- 1
- 2
- 3
- 4
- 5
- 6
- 7

Colaborador

Equipe Técnica

Gestor de Segurança

DPO / Encarregado de Dados

Alta Administração

ANPD

Titulares

3.8.1 Comunicação para ANPD



Quando comunicar?

A comunicação deve ocorrer quando houver **risco ou dano relevante** aos titulares.

Informações normalmente enviadas:

01 Natureza do incidente

02 Dados afetados

03 Quantidade estimada

04 Medidas adotadas

05 Riscos envolvidos

06 Ações mitigadoras

3.8.2 Comunicação aos Titulares



Exemplo de Mensagem

"Ocorreu um incidente de segurança que pode ter exposto seus dados pessoais. Adotamos medidas imediatas para conter o problema..."

Como deve ser a comunicação:

01 Clara

02 Objetiva

03 Transparente

04 Sem linguagem técnica excessiva

4. Sanções Administrativas da LGPD



Sanções da ANPD

A autoridade nacional pode aplicar punições administrativas aos agentes de tratamento de dados que violarem a lei.

Obs: as sanções podem ser aplicadas de forma isolada ou cumulativa.

01 Advertência

02 Multa simples

03 Multa diária

04 Publicização

05 Bloqueio de dados

06 Eliminação de dados

07 Suspensão parcial

08 Proibição de tratar

5. Multas da LGPD



Obs: O valor depende de diversos critérios considerados pela ANPD, como gravidade da infração, boa-fé, cooperação, reincidência e adoção de medidas corretivas.

A LGPD estabelece que a multa simples pode alcançar:

01 Até 2% do faturamento da pessoa jurídica;

02 Limitada a 50 milhões por infração.

Referências - LGPD

ANPD. AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Guia Orientativo: Tratamento de Dados Pessoais pelo Setor de Saúde. Brasília, DF: ANPD, 2021.

BRASIL. [Lei nº 13.709, de 14 de agosto de 2018]. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, [2018]. Disponível em: http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm.

FRAZÃO, Ana; TEPEDINO, Gustavo. Lei Geral de Proteção de Dados Pessoais: conceitos fundamentais. São Paulo: Revista dos Tribunais, 2020.

ISO. INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27701: Security techniques — Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management — Requirements and guidelines. Geneva: ISO, 2019.

Referências - ePING E INTEROPERABILIDADE

BRAGA, Renata Dutra et al. (org.). Padrões: introdução. 2. ed. Goiânia: Cegraf UFG, 2023. E-book. 83 p. ISBN 978-85-495-0691-7. Disponível em: <http://repositorio.bc.ufg.br/handle/ri/22640>.

BRASIL. Ministério do Planejamento, Orçamento e Gestão. Secretaria de Logística e Tecnologia da Informação. Guia de Interoperabilidade: Cartilha Técnica. Brasília, DF: MP, 2015. 90 p.

E-PING. ePING: Programa de Governo Eletrônico Brasileiro. Brasília, DF: Governo Eletrônico, 2014. Disponível em: <http://www.eping.e.gov.br>.

FERRÉ, Felipe. Gestão de dados de saúde. Organização de Renata Dutra Braga et al. 1. ed. Goiânia: Cegraf UFG, 2024. E-book. ISBN 978-85-495-1042-6.

PET-SAÚDE-DIGITAL

Introdução à Interoperabilidade na
Saúde

Dúvidas?



UNIVERSIDADE
FEDERAL DO PIAUÍ

